

SQL Injection Detected

Ticket :	SOC127 - SQL Injection Detected
MITRE ATT&CK :	T1595 T1133 T1199 T1552.001
Request URL :	GET /?doui=3034%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1 200 865
Device Action :	Allowed
Source Address :	118.194.247.28
Destination Address :	172.16.20.12
Destination Hostname :	WebServer1000

A primeira coisa a se fazer é analisar os logs

42 events found

Filters

Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

raw_log

Event

2024-03-07 06:53:09 | Proxy | 118.194.247.28:48751 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:53:09 +0000] "GET /index.php?id=1%26AND%2020574%3DCAST%26%2BCHR%28113%29%2F%2BCHR%2810%2F%29%2F%2BCHR%28%22XSS%22%29%3C%2Fscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

2024-03-07 06:53:08 | Proxy | 118.194.247.28:47656 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:53:08 +0000] "GET /index.php?id=1%26AND%209816%3D9452-%20%2BCHR%2810%2F%29%2F%2BCHR%28%22XSS%22%29%3C%2Fscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

2024-03-07 06:53:08 | Proxy | 118.194.247.28:47656 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:53:08 +0000] "GET /index.php?id=1%26AND%209816%3D9452-%20%2BCHR%2810%2F%29%2F%2BCHR%28%22XSS%22%29%3C%2Fscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

2024-03-07 06:53:08 | Proxy | 118.194.247.28:47656 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:53:08 +0000] "GET /index.php?id=1%26AND%209816%3D9452-%20%2BCHR%2810%2F%29%2F%2BCHR%28%22XSS%22%29%3C%2Fscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

2024-03-07 06:53:07 | Proxy | 118.194.247.28:28075 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:53:07 +0000] "GET /index.php?id=1%27QmEOK%3C%27%22%3EPRVokd HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

2024-03-07 06:51:45 | Proxy | 118.194.247.28:45163 -- 172.16.20.12:80 | Raw Data: 118.194.247.28 -- [07/Mar/2024:12:51:45 +0000] "GET /?doui=3034%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (https://sqlmap.org)"

RAW DATA

Field

Value

type

source_address

source_port

destination_address

destination_port

time

Raw Log

Raw Data

Observando o User-Agent é possível afirmar que é uma varredura feita pelo sqlmap

É bom checar o email se isso não foi um teste agendado, pesquisando no servidor de email por mensagens contendo o nome ou IP do host, nesse caso não existem indícios de que isso foi programado

Recipe

URL Decode

Treat "+" as space

Input

=3034%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%3Ctable_name%20FROM%20information_schema.tables%20WHERE%20%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20. %2F. %2F. %2Fetc%2Fpasswd%27%29%23 HTTP/1.1 200 865

Output

=3034 AND 1=1 UNION ALL SELECT 1,NULL,'<script>alert("XSS")</script>',table_name FROM information_schema.tables WHERE 2>1--/**/; EXEC xp_cmdshell('cat ../../../../etc/passwd')# HTTP/1.1 200 865

Decodando a URL fica mais fácil de saber o que o atacante está fazendo.

9

/ 91

Community Score

🔄

9/91 security vendors flagged this IP address as malicious

🔄

Reanalyze

More

118.194.247.28 (118.194.246.0/23)

AS 4808 (China Unicom Beijing Province Network)

CN

Last Analysis Date

2 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 3

Join our **Community** and enjoy additional community insights and crowdsourced detections, plus an API key to **automate checks**.

Security vendors' analysis

Do you want to automate checks?

alphaMountain.ai	🔴 Malicious	BitDefender	🔴 Phishing
Chong Lua Dao	🔴 Malicious	CyRadat	🔴 Malicious
Forcepoint ThreatSeeker	🔴 Malicious	Fortinet	🔴 Malware
G-Data	🔴 Phishing	Lionic	🔴 Malicious

O IP que está fazendo o ataque pode ser considerado um pouco suspeito, mas não necessariamente nesse caso.

Observando os logs é possível ver que todos retornam 200 865, ou seja, os comandos estão sendo enviados com sucesso devido ao status code 200 e device action = allowed, mas a resposta do servidor retorna o mesmo tamanho, **CUIDADO**, em outros casos isso poderia ser considerado um ataque de sql injection falho, **MAS** isso só seria efetivo se os logs fossem diretos do web server, nesse caso os logs são do proxy, o que torna isso inconclusivo

Processes	Network Action	Terminal History	Browser History	Results
EVENT TIME	COMMAND LINE			
2023-11-10 09:25:44	ping google.com			
2023-11-10 09:24:51	sudo apt-get install iftop			
2023-11-10 09:23:15	/usr/bin/python3 /usr/lib/ubuntu-release-upgrader/check-new-release -q			
2023-11-10 09:23:00	whoami			
2023-11-10 09:16:55	exit			
2023-11-10 09:16:41	cat proxy.conf			
2023-11-10 09:16:24	vi proxy.conf			
2023-11-10 09:16:17	touch proxy.conf			
2023-11-10 09:15:49	ls			
2023-11-10 09:15:35	cd apt.conf.d/			

Processes	Network Action	Terminal History	Browser History	Results
EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
2023-11-10 09:25:50.596	3676	bash	gnome-terminal-server	bash
2023-11-10 09:25:50.588	3530	gnome-terminal-server	—	/usr/libexec/gnome-terminal-server
2023-11-10 09:25:44.975	3537	bash	gnome-terminal-server	bash
2023-11-10 09:24:52.296	3631	apt-get	sudo	apt-get install iftop
2023-11-10 09:24:51.801	3634	dash	apt-get	/bin/sh -c [! -f /usr/bin/snap] /usr/bin/snap ...
2023-11-10 09:24:51.776	3634	dash	apt-get	/bin/sh -c [! -f /usr/bin/snap] /usr/bin/snap ...
2023-11-10 09:24:51.775	3631	apt-get	sudo	apt-get install iftop
2023-11-10 09:24:51.268	3631	apt-get	sudo	apt-get install iftop
2023-11-10 09:24:51.262	3630	sudo	bash	sudo apt-get install iftop
2023-11-10 09:24:51.25	3537	bash	gnome-terminal-server	bash

Avaliando o histórico de processos e do terminal do servidor, não foi possível identificar nada necessariamente suspeito.

Devido a inconclusão sobre identificar se o ataque realmente deu certo ou não, seria necessário escalar para o N2 para identificação.

T1190 - Exploit Public-Facing Application

Horário:

2024-03-07 06:51:45

IoCs:

Endereços IP:

118.194.247.28

URL explorada:

"GET /?doux=3034 AND 1=1 UNION ALL SELECT 1,NULL,'<script>alert("XSS")</script>';table_name FROM information_schema.tables WHERE 2>1--/**/; EXEC xp_cmdshell('cat ../../etc/passwd')# HTTP/1.1" 200 865 "-" "sqlmap/1.7.2#stable (<https://sqlmap.org>)"

Análise:

O atacante iniciou um ataque com sqlmap contra o servidor WEB de IP 172.16.20.12, de acordo com os logs registrados pelo proxy, todos deram 200 como status code, mas retornaram sempre o mesmo tamanho de resposta 865, como os logs vêm do proxy e não diretamente do servidor não é possível concluir se o ataque foi ou não bem-sucedido, analisando os processos e comandos executados no servidor não foi detectado nada suspeito ou evidência de execução dos comandos EXEC do sql feitos pelo atacante, o IP também não necessariamente foi dado como malicioso, devido a inconclusão o caso foi encaminhado para o N2 concluir.

Recomendações:

- Aplicar menor privilégio na conta sendo usada pela aplicação no banco
- Melhorar o logging
- Revisar regras WAF ou colocar um caso não tiver para bloquear esse tipo de ataque
- Validar e sanitizar inputs